Northfield University Office of Information Technology

Identity Security and Multi-Factor Authentication Standard

Field	Detail
Policy Number	NUOIT Policy 2025-IAM-02
Title	Identity Security and Multi-Factor Authentication Standard
Effective Date	January 15, 2025
Version	1.0
Classification	Public — University-Wide
Supersedes	Select provisions of NUOIT Policy 2023-IAM-01 (Password and Credential Management Policy)
Approved By	Dr. Priya Venkataraman, Vice Provost for Information Technology & Chief Information Officer
Review Cycle	Annual (next review: January 2026)

1.0 Purpose

The purpose of this standard is to establish a modern, risk-based framework for identity security and multi-factor authentication (MFA) at Northfield University. As cyber threats continue to evolve — with credential theft, phishing, and account takeover attacks increasing in both frequency and sophistication — the university must adopt identity and access management (IAM) practices aligned with current federal guidance and industry best practices.

This standard consolidates and updates the university's approach to authentication, password management, privileged access, and account lifecycle governance. It reflects the shift from perimeter-based security toward a **Zero Trust architecture** in which identity verification is the primary control plane for protecting institutional data and systems.

2.0 Scope

This standard applies to:

- **All members of the Northfield University community**, including faculty, staff, students, contractors, visiting scholars, and affiliates who are issued a Northfield NetID or granted access to university information systems.
- **All university-managed information systems**, including but not limited to: enterprise applications (e.g., Banner, Workday), learning management systems (e.g., Brightspace), email and collaboration platforms (Microsoft 365), research computing environments, VPN and remote access services, cloud-hosted services authenticated via Northfield SSO, and administrative and financial systems.
- **Third-party service providers and vendors** who access university systems or data under contractual agreements, as governed by the Vendor Risk Management Policy (NUOIT Policy 2024-VRM-01).

2.1 Relationship to Other Policies

This standard should be read in conjunction with the following Northfield University policies:

- **NUOIT Policy 2023-IAM-01** — Password and Credential Management Policy *(partially superseded by this standard; see Section 2.3)*
- **NUOIT Policy 2024-SEC-01** — Acceptable Use of Information Technology Resources
- **NUOIT Policy 2024-GOV-01** — Data Classification and Handling Policy
- **NUOIT Policy 2024-VRM-01** — Vendor Risk Management Policy
- **NUOIT Policy 2024-IR-01** — Cybersecurity Incident Response Plan

Where conflicts exist between this standard and previously published policies, **this standard shall take precedence** as the more recent and authoritative document.

2.2 Multi-Factor Authentication (MFA) Requirements

Northfield University mandates the use of multi-factor authentication (MFA) for all authenticated access to university information systems. MFA combines two or more independent authentication factors to verify a user's identity:

1. **Something you know** — a password, passphrase, or PIN.
2. **Something you have** — a hardware security key (e.g., FIDO2/WebAuthn-compliant device), a registered mobile device running an authenticator application (e.g., Microsoft Authenticator, Duo Mobile), or a one-time passcode (OTP) delivered via push notification.
3. **Something you are** — a biometric factor such as a fingerprint or facial recognition, where supported by the endpoint device.

2.2.1 Universal MFA Enrollment

Effective January 15, 2025, all holders of a Northfield NetID are **required** to enroll in MFA within 14 calendar days of account activation. Accounts that have not completed MFA enrollment after the 14-day grace period will be restricted to on-campus, wired-network access only until enrollment is completed.

2.2.2 Approved MFA Methods

The following MFA methods are approved for use, listed in order of preference (strongest to weakest):

Priority	Method	Notes
1 (Preferred)	**FIDO2 / WebAuthn hardware security key**	Phishing-resistant; strongly recommended for privileged accounts
2	**Microsoft Authenticator push notification**	Default method for most users
3	**TOTP authenticator app** (e.g., Google Authenticator)	Acceptable alternative
4	**SMS one-time passcode**	Permitted only as a fallback; subject to SIM-swap risk

SMS-based OTP will be deprecated as an approved MFA method effective July 1, 2026. Users relying on SMS are encouraged to transition to a stronger method before that date.

2.2.3 MFA-Protected Services

MFA is required for access to all of the following services, regardless of network location (on-campus or off-campus):

- Northfield SSO (Shibboleth / CAS) — the central authentication gateway
- Microsoft 365 (email, Teams, SharePoint, OneDrive)
- VPN (GlobalProtect)
- Learning Management System (Brightspace)
- Student Information System (Banner)
- Human Resources and Financial systems (Workday)
- Research computing clusters and data enclaves
- Administrative consoles and IT management tools
- All SaaS applications integrated via Northfield SSO

2.3 Password Policy Update

In compliance with **NIST Special Publication 800-63B** (Digital Identity Guidelines), the Office of IT has adopted the following updated password standards effective January 2025: **Mandatory periodic password expiration (e.g., 90-day rotation) is prohibited.** Passwords shall only be changed when there is evidence of compromise or at the user's request. This supersedes Section 4.1 of the Password and Credential Management Policy (NUOIT Policy 2023-IAM-01). **Multi-factor authentication (MFA) is required for all university account access**, including VPN, email, learning management systems, and administrative applications.

The rationale for eliminating mandatory rotation is well established in current research and federal guidance:

- **NIST SP 800-63B, Section 5.1.1.2** explicitly advises that verifiers "SHALL NOT require memorized secrets to be changed arbitrarily (e.g., periodically)." Forced rotation leads users to select weaker passwords, increment predictable suffixes, or reuse credentials across services — all of which increase institutional risk.
- **Multi-factor authentication** provides a far stronger compensating control than password rotation. With MFA universally enforced, a compromised password alone is insufficient to gain unauthorized access.

2.3.1 Updated Password Requirements

The following password requirements replace and supersede the corresponding provisions of NUOIT Policy 2023-IAM-01:

Requirement	Standard
Minimum length	12 characters (16+ recommended)
Maximum length	At least 64 characters must be supported by all systems
Complexity rules	No mandatory composition rules (e.g., requiring uppercase, symbols). Users are encouraged but not required to use mixed character types.
Periodic expiration	**Prohibited.** Passwords do not expire on a schedule.
Compromised credential screening	All passwords are checked at creation and at each authentication event against known breached-credential databases (e.g., HIBP, internal threat intelligence feeds).
Password change triggers	A password change is required only when: (a) a credential compromise is detected or suspected, (b) the user voluntarily requests a change, or (c) the IT Security Office directs a change in response to a security incident.
Passphrase guidance	Users are encouraged to use long passphrases (e.g., four or more random words) rather than short, complex passwords.
Credential storage	All passwords must be hashed using an approved algorithm (bcrypt, scrypt, Argon2id) with per-user salting. Plaintext or reversibly encrypted storage is strictly prohibited.

2.3.2 Transition and Coexistence

During the transition period (January 15, 2025 through June 30, 2025), the following provisions apply:

- The automatic 90-day password expiration enforcement in Active Directory and Northfield SSO will be **disabled** for all standard user accounts by March 1, 2025.
- Accounts that were already subject to a pending password expiration notification before the effective date of this standard will have their expiration deadline extended by 180 days automatically.
- Departmental systems that enforce local password rotation policies must submit a waiver request to the IT Security Office (security@northfield.edu) or update their configurations to align with this standard by June 30, 2025.
- The legacy Password and Credential Management Policy (NUOIT Policy 2023-IAM-01) remains in effect for provisions not explicitly superseded by this standard, including Sections 5.0 (Service Account Credentials) and 6.0 (Credential Transmission Standards).

3.0 Single Sign-On (SSO) Integration

3.1 SSO Architecture

Northfield University operates a centralized Single Sign-On (SSO) infrastructure based on **Shibboleth Identity Provider (IdP)** and **CAS (Central Authentication Service)**. All university applications — whether on-premises or cloud-hosted — must authenticate users through the Northfield SSO gateway unless a documented exception has been approved by the Chief Information Security Officer (CISO).

3.2 Application Onboarding

New applications and services procured or developed by university departments must be evaluated for SSO compatibility during the procurement or development process. Requirements include:

- Support for **SAML 2.0** or **OpenID Connect (OIDC)** protocols.
- No local credential stores; authentication must be delegated to the Northfield IdP.
- Attribute release limited to the minimum necessary for application functionality, in accordance with the Data Classification and Handling Policy (NUOIT Policy 2024-GOV-01).
- Completion of a **Service Provider Registration Form** submitted to the Identity and Access Management team (iam@northfield.edu).

Applications that cannot support federated authentication must obtain a **Security Exception** and implement compensating controls, including dedicated MFA enrollment and enhanced logging.

3.3 Session Management

- SSO session duration shall not exceed **10 hours** for standard users.
- Re-authentication via MFA is required after session timeout, device change, or access to applications classified as handling **Restricted** or **Highly Restricted** data.
- Step-up authentication (additional MFA prompt) is enforced for high-risk transactions, including changes to account recovery settings, access to financial systems, or export-controlled research data.

4.0 Privileged Access Management (PAM)

4.1 Definition of Privileged Accounts

Privileged accounts are those with elevated permissions beyond those of a standard user, including but not limited to:

- Domain administrator and enterprise administrator accounts in Active Directory
- Root and sudo-capable accounts on Linux/Unix systems
- Database administrator (DBA) accounts
- Cloud infrastructure administrative roles (e.g., Azure Global Administrator, AWS IAM Administrators)
- Application administrator accounts for enterprise systems (Banner, Workday, Brightspace)
- Service accounts with write access to production systems or sensitive data stores

4.2 Privileged Access Controls

The following controls are mandatory for all privileged accounts:

1. **Dedicated privileged accounts.** Administrators must use a separate, dedicated privileged account (e.g., `adm-jsmith`) distinct from their standard NetID for all administrative activities. Use of a standard NetID for privileged operations is prohibited.
2. **Phishing-resistant MFA.** Privileged accounts must use a **FIDO2/WebAuthn hardware security key** as the primary MFA factor. Authenticator app push notifications are accepted as a secondary option; SMS-based OTP is **not permitted** for privileged accounts under any circumstances.

3 **Just-in-time (JIT) access.** Where technically feasible, privileged access should be provisioned on a just-in-time basis using a Privileged Access Management (PAM) solution (e.g., CyberArk, BeyondTrust). Standing privileged access must be justified and reviewed quarterly.

4 **Session recording and monitoring.** All privileged sessions on critical infrastructure must be recorded and retained for a minimum of 12 months. Anomalous privileged activity will trigger automated alerts to the Security Operations Center (SOC).

5 **Credential vaulting.** Shared or service account credentials must be stored in an approved enterprise password vault. Direct knowledge of privileged passwords by individual administrators should be avoided where vault-based checkout workflows are available.

4.3 Privileged Access Reviews

The IT Security Office will conduct **quarterly access reviews** of all privileged accounts. Department IT liaisons are required to certify the continued need for each privileged account assigned to their area. Accounts not certified within 30 days of review initiation will be suspended.

5.0 Account Lifecycle and Deprovisioning

5.1 Account Provisioning

Northfield NetID accounts are provisioned through automated feeds from authoritative source systems:

- **Faculty and Staff:** HR system (Workday) triggers account creation upon hire action. Accounts are provisioned within one business day of the hire effective date.
- **Students:** Student Information System (Banner) triggers account creation upon admission deposit or registration. Accounts are provisioned within two business days.
- **Affiliates and Contractors:** Sponsored accounts are requested by an authorized university sponsor through the Identity Management Portal and are subject to approval by the department head and the IT Security Office.

5.2 Account Deprovisioning

Timely deprovisioning of accounts is critical to reducing the university's attack surface. The following deprovisioning timelines are mandatory:

Account Type	Trigger Event	Deprovisioning Timeline
Faculty / Staff	Separation date in Workday	Access disabled within **24 hours** of separation; account deleted after 90 days
Students	Graduation, withdrawal, or two consecutive semesters of non-enrollment	Access disabled within **7 days** of trigger; account deleted after 180 days
Affiliates / Contractors	Sponsorship end date or sponsor revocation	Access disabled within **24 hours** of end date
Privileged accounts	Role change or separation	Access disabled **immediately** upon notification; reviewed by IT Security within 4 hours

5.3 Account Suspension and Reactivation

- Accounts may be suspended without prior notice by the IT Security Office in response to a suspected security incident, policy violation, or law enforcement request, consistent with the Cybersecurity Incident Response Plan (NUOIT Policy 2024-IR-01).
- Reactivation of suspended accounts requires written approval from the account holder's supervisor (for employees) or academic advisor (for students), plus clearance from the IT Security Office.
- Accounts that have been deleted cannot be restored. A new account provisioning request must be submitted.

6.0 Compliance and Enforcement

6.1 Compliance Monitoring

The IT Security Office will monitor compliance with this standard through:

- Automated reporting on MFA enrollment rates, with monthly dashboards distributed to college and department leadership.
- Periodic audits of password policy configuration across Active Directory, Azure AD, and integrated applications.
- Privileged access certification campaigns conducted quarterly.
- Annual penetration testing exercises that include credential-based attack simulations.

6.2 Non-Compliance

Failure to comply with this standard may result in:

- Temporary restriction or suspension of network and system access.
- Referral to the appropriate disciplinary process: Human Resources (staff), the Provost's Office (faculty), or the Office of Student Conduct (students).
- For third-party vendors, non-compliance may constitute a breach of contractual obligations and result in termination of access or the vendor agreement.

6.3 Exception Requests

Requests for exceptions to any provision of this standard must be submitted in writing to the IT Security Office at **security@northfield.edu** using the Security Exception Request Form. Exceptions require approval by the CISO and are granted for a maximum of 12 months, after which they must be renewed with updated justification.

7.0 Definitions

Term	Definition
MFA	Multi-Factor Authentication — an authentication method requiring two or more independent verification factors.
NetID	The unique username assigned to each member of the Northfield University community for accessing IT resources.
FIDO2 / WebAuthn	An open authentication standard that enables passwordless or phishing-resistant login using hardware security keys or platform authenticators.
Zero Trust	A security model that assumes no implicit trust based on network location; every access request is verified explicitly.
JIT Access	Just-In-Time access provisioning, where elevated privileges are granted only for the duration needed to complete a specific task.
PAM	Privileged Access Management — tools and processes for controlling, monitoring, and auditing privileged account usage.
SSO	Single Sign-On — an authentication scheme that allows users to access multiple applications with a single set of credentials.

8.0 Revision History

Version	Date	Author	Description
1.0	January 15, 2025	Office of IT, Identity & Access Management Division	Initial release. Supersedes select provisions of NUOIT Policy 2023-IAM-01.

Synthetic document for a take-home assignment. Not an official NYU policy. | Northfield University Office of IT